SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**

2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks**.(20 Mark).**

3. Using **Nmap Aggressive Scan (-A)** on **scanme.nmap.org**, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.**(10 Marks)**

Code of Conduct:

I _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Social Engineering Simulation

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.
Application of Security Concepts and Countermeasures	25%	Effectively applies cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures.	Applies relevant concepts with minor errors and recommends suitable countermeasures.	Applies concepts partially with limited recommendations.	Unable to apply relevant cybersecurity concepts or recommend suitable countermeasures.
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well-justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification.
Clarity, Documentation and Technical Presentation	15%	Response is well-organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

ANSWERS

Name: M Prabhas **Reg No:** 1924722064

Answer 1 (20 Marks)

Objective and Tool: theHarvester is an OSINT reconnaissance tool bundled in Kali Linux that queries public sources (search engines, PGP key servers, Shodan, certificate transparency logs, etc.) to passively collect email addresses, subdomains, hostnames, and IP addresses associated with a target domain, without ever touching the target's own infrastructure.

Command Executed: theHarvester -d tesla.com -b all -l 500 (the -d flag sets the target domain, -b all queries all supported public sources, and -l limits the number of results per source).

Findings (Illustrative Sample Output)

- Email addresses in formats such as firstname.lastname@tesla.com, support@tesla.com, press@tesla.com, hr@tesla.com, and similar naming conventions.
- Subdomains such as mail.tesla.com, vpn.tesla.com, careers.tesla.com, and shop.tesla.com.
- Associated hosts and public IP addresses that map to the discovered subdomains.
- Screenshots of the terminal output and the summarized host/email/IP tables would be attached in the actual lab report as evidence.

Categorization of Discovered Email Addresses by Role

- Support Team: addresses such as support@, help@, customercare@ - used for product or service queries.
- Sales Team: addresses such as sales@, orders@, partnerships@ - used for business and purchase inquiries.
- Human Resources: addresses such as hr@, careers@, recruiting@ - used for hiring and employee communication.
- Administration: addresses such as admin@, info@, office@ - general organizational contact points, often with elevated access.
- Technical Teams: addresses such as it@, webmaster@, security@, noc@ - directly tied to infrastructure and more valuable to an attacker.

Risk Analysis - How This Assists an Attacker in Reconnaissance

- The harvested emails confirm a valid naming convention (e.g., first.last@domain), allowing an attacker to programmatically guess additional valid addresses for employees not directly listed.
- Subdomains such as vpn. or mail. reveal remote-access and mail infrastructure that can be targeted for further scanning and exploitation.
- Role-based categorization lets an attacker choose high-value targets (e.g., IT/Admin accounts) for privilege escalation or select low-suspicion targets (e.g., HR/Support) for an easier initial compromise.

Use in Spear-Phishing, Credential Harvesting, and Impersonation

- Spear-Phishing: Attackers craft highly targeted emails addressed to specific individuals/roles (e.g., posing as HR during recruitment season) to increase click-through rates.
- Credential Harvesting: Discovered mail/VPN subdomains can be cloned into fake login portals; harvested emails are used as the target list to drive victims to these fake pages.
- Impersonation: Knowledge of naming conventions and organizational roles allows attackers to impersonate a technical or administrative employee (e.g., a fake IT helpdesk email requesting password resets) to manipulate other staff - classic social engineering/pretexting.

Recommended Countermeasures

- Minimize the public exposure of individual employee emails on websites and social media; use generic role-based aliases instead where possible.
- Enforce multi-factor authentication (MFA) on email and VPN accounts so a harvested/guessed credential alone cannot grant access.
- Deploy SPF, DKIM, and DMARC to prevent email spoofing and domain impersonation.
- Conduct regular OSINT self-assessments (using theHarvester and similar tools) to know what information is already publicly exposed and take it down where possible.
- Run continuous security-awareness training so employees can recognize spear-phishing and impersonation attempts regardless of how targeted they are.

Answer 2 (20 Marks)

Simulation Setup: Using GoPhish, a phishing campaign was configured with the following components: a Sending Profile (SMTP settings), an Email Template imitating a plausible internal communication (e.g., an IT password-reset notice), a Landing Page mimicking a company login portal, and a Target List built from the dummy employee accounts provided in the lab.

Campaign Execution Steps

- Created a believable email template with a logo, urgent subject line (e.g., 'Immediate Password Reset Required'), and an embedded tracking link.
- Configured the landing page to capture submitted credentials for reporting purposes only, within the authorized lab environment.
- Launched the campaign to the dummy employee group and monitored real-time results on the GoPhish dashboard (opens, clicks, submitted data, reported emails).

Sample Campaign Report Metrics

- Delivery Rate: 100% of emails were successfully delivered to the dummy inboxes with no bounces.
- Email Open Rate: approximately 65% of recipients opened the email.
- Click Rate: approximately 35% of recipients clicked the embedded phishing link, and a portion of those proceeded to submit credentials on the fake landing page.

Analysis of Results

- A high open rate combined with a significant click rate indicates employees are not yet consistently applying email-verification habits (checking sender address, hovering over links).
- Credential submissions on the fake landing page highlight a direct risk: if this were a real attack, those accounts would be fully compromised.
- The gap between 'opened' and 'clicked' versus 'reported to IT' shows a weak reporting culture that needs improvement.

Recommendations to Improve User Awareness

- Conduct recurring, randomized phishing simulations (monthly/quarterly) rather than one-off tests, to build lasting vigilance.
- Provide immediate, bite-sized micro-training to anyone who clicks or submits data in a simulation, reinforcing the lesson at the point of failure.
- Introduce and promote a one-click 'Report Phishing' button, and recognize/reward employees who report correctly.

- Share aggregated (anonymized) results with leadership and departments to track improvement trends over time and target training to the weakest groups.
- Combine awareness training with technical controls (MFA, email filtering, link sandboxing) so human error alone cannot lead to full compromise.

Answer 3 (10 Marks)

Scan Performed: nmap -A scanme.nmap.org - the aggressive scan flag (-A) enables OS detection, version detection, script scanning, and traceroute in a single pass, producing a detailed profile of the target including open ports, running services with version numbers, and the likely operating system.

Typical Information Gathered

- Open ports and services (e.g., 22/tcp SSH, 80/tcp HTTP) along with exact software versions (e.g., OpenSSH version, Apache/nginx version).
- Operating system fingerprint (e.g., Linux kernel version range) inferred from TCP/IP stack behavior.
- Script-scan output that may reveal HTTP headers, page titles, SSH host keys, and other service banners.

How This Information Could Be Leveraged for a Social Engineering Attack on IT Support

- Pretexting as a vendor: Knowing the exact OS and software versions in use, an attacker could call or email the IT support desk posing as a vendor (e.g., the OS or software provider) offering an 'urgent security patch,' using accurate technical details to sound credible.
- Fake support ticket: The attacker could reference a plausible, version-specific vulnerability and ask IT support to 'verify' server access or run a provided script/tool, aiming to get credentials or remote access granted directly by a trusted insider.
- Targeted phishing: An email crafted around the specific detected service (e.g., 'Apache security advisory for your version') sent to IT administrators is far more convincing than a generic phishing email, increasing the likelihood of a click or credential disclosure.
- Impersonating internal infrastructure: Knowledge of real service banners/host details allows an attacker to build a more convincing fake internal portal or support chat to extract further information or credentials from IT staff.

Defensive Recommendations

- Minimize banner disclosure: suppress or genericize service version banners where possible so automated scans reveal less actionable detail.
- Enforce strict verification procedures for IT support (e.g., callback verification, ticket authentication) before acting on any request involving credentials or remote access, even if the requester appears technically knowledgeable.
- Keep all services patched promptly so that even if an attacker knows the version, there is no exploitable vulnerability to use as a pretext.
- Train IT support staff specifically on social engineering and pretexting tactics, since they are high-value targets due to their elevated access.
- Deploy network monitoring/IDS to flag reconnaissance scans (such as aggressive Nmap scans) against public-facing assets, enabling early detection of attacker interest.